

[ffuf]- 쌤 수업 있으면 좋을거같아요/.....

1.정의

ffuf(Fuzz Faster U Fool)는 Go로 개발된 웹 퍼징 툴이다.

웹 서비스에 대한 모의해킹을 진행하거나 침투 테스트를 진행하는 경우 공격 대상 서버에 디렉터리 스캔을 하거나, 서브 도메인을 스캔하는 작업이 필요한 경우에 ffuf 툴을 사용하여 간단하게 스캔이 가능하다.

URL 구조, 숨겨진 디렉터리, 파일, 서브도메인. 파라미터 등을 자동으로 대량 요청해서 존재하는 자원만 찾아내는 도구이다.

숨겨진 페이지 찾기. 관리자 페이지 / 백업파일 / 개발용 폴더 찾기 / 파라미터 이름 찾기 / 서브도메인 찾기 / 파일 업로드 취약점 테스트 / 서버 응답 기반 정보 수집

2. 왜 쓰는가

1) 숨겨진 디렉터리 / 파일 발견

/admin/, /backup/, /test/, /dev/ 등이 웹 서버에 실제로 있지만 노출되지 않은 경우.

2) 내부 API 엔드포인트 찾기.

/api/v1/user, /api/v2/login 등.

3) 파라미터 이름 찾기

page=@@@, id=@@@, cmd=@@@ 같은 파라미터를 추측해서 공격 가능성 확인

4) 서브 도메인 퍼징

admin.han.com , quest.han.com

5) 파일 업로드 취약점 분석

업로드 후 경로를 모르는데 ffuf가 파일 저장 경로를 찾을 수 있음.

6) 버그바운티 / 모의해킹 표준 도구

Dirsearch보다 더 빠르고 정교하게 옵션 조절 가능해서 실무에서도 많이 쓰인다.

3. 사용법

sudo apt install ffuf

```
$ sudo apt install ffuf
[sudo] password for kali:
ffuf is already the newest version (2.1.0-1+b9).
ffuf set to manually installed.
```

```
ffuf -u http://target.com/FUZZ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
```

```
(kali㉿kali)-[~]
$ ffuf -u http://target.com/FUZZ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
```

v2.1.0-dev

```
:: Method      : GET
:: URL        : http://target.com/FUZZ
:: Wordlist    : FUZZ: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
```

디렉터리 퍼징

-> 웹서버에 존재하는 숨겨진 폴더를 추측해서 자동으로 찾아내는 과정이다.

```
(kali@kali)~$ ffuf -u https://www.ubiedu.co.kr/FUZZ \
-w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt \
-fc 404

      _____
     /  _  _  _  \
    /  _ \| | | |\
   /  _ \| |_| | |\
  /  _ \|  _  | |\
 /  _ \| | | | |\
/  _ \| |_| | |\
\  _ \|  _  | |\
 \  _ \| | | | |\
  \  _ \| |_| | |\
   \  _ \|  _  | |\
    \  _ \| | | | |\
     \  _ \| |_| | |\
      \_|\_\_|_|_\|
      v2.1.0-dev

:: Method      : GET
:: URL         : https://www.ubiedu.co.kr/FUZZ
:: Wordlist     : FUZZ: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
:: Follow redirects : false
:: Calibration   : false
:: Timeout      : 10
:: Threads      : 40
:: Matcher      : Response status: 200-299,301,302,307,401,403,405,500
:: Filter       : Response status: 404

:: Progress: [16/220560] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] ::
:: Progress: [40/220560] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] ::
# or send a letter to Creative Commons, 171 Second Street, [Status: 200, Size: 49654, Words: 22108, Lines: 760, Duration: 18ms]
:: Progress: [43/220560] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] ::
# [Status: 200, Size: 49654, Words: 22108, Lines: 760, Duration: 7ms]
:: Progress: [44/220560] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] ::
# directory-list-2.3-medium.txt [Status: 200, Size: 49654, Words: 22108, Lines: 760, Duration: 27ms]
:: Progress: [45/220560] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] ::
```

4. 실습?

```
login [Status: 301, Size: 235, Words: 14, Lines: 8, Duration: 3ms]
:: Progress: [157/220560] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] ::
admin [Status: 301, Size: 235, Words: 14, Lines: 8, Duration: 4ms]
:: Progress: [312/220560] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] ::
:: Progress: [1038/220560] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] ::
backup [Status: 301, Size: 236, Words: 14, Lines: 8, Duration: 10ms]
```

login / admin / backup 디렉터리 존재를 확인할수 있다.

단점...?

뭔가 너무 복잡하고... 어케 분석? 이용할지 음 애매하다...